Business Impact Analyse (BIA) & Kritikalitätskatalog

Dokumenten-ID: BCM-BIA-2026-V3 | Klassifizierung: Vertraulich (Min. Role L2) | Gültig ab: 01.10.2026

2 Stunden	250.000 EUR	6 Monate
ZIEL-RTO TIER 1 (NEU)	SCHADENSSCHWELLE / TAG	BIA-REVISIONSZYKLUS

§ 1 Methodik und Zweck der Business Impact Analyse (BIA)

Die Business Impact Analyse (BIA) bildet die verbindliche Grundlage für das gesamte Business Continuity Management (BCM) nach ISO 22301 und BSI-Standard 200-4. Sie ermittelt, welche Geschäftsprozesse und unterstützenden IT-Applikationen für das Überleben des Unternehmens unverzichtbar sind und welche finanziellen, regulatorischen sowie operativen Schäden bei einem Ausfall eintreten. Im Gegensatz zur allgemeinen Risikomanagement-Richtlinie muss die BIA für alle geschäftskritischen Prozesse zwingend alle **6 Monate** (halbjährlich) aktualisiert und durch die Bereichsleiter validiert werden.

§ 2 Verbindliche Wiederanlauf-Parameter (RTO, RPO & MTPD)

Aufgrund verschärfter Kunden-SLAs im Geschäftsjahr 2026 wurden die Wiederanlaufzeiten (RTO), die maximal zulässigen Datenverluste (RPO) sowie die maximal tolerierbare Ausfalldauer (MTPD) wie folgt neu festgelegt:

Prozess-Klasse	Zugeordnete Kernprozesse & IT-Assets	RTO (Wiederanlauf)	RPO (Datenverlust)	MTPD (Max. Ausfall)
Tier 1 (Kritisch)	Identity Provider (AD/Entra), Zahlungsabwicklung, Produktionsleitstand, Core-Firewall	**2 Stunden**	**30 Minuten**	6 Stunden
Tier 2 (Hoch)	Kundenportal, ERP-Auftragsbearbeitung, E-Mail-Kommunikation, VPN-Concentrator	**8 Stunden**	**2 Stunden**	24 Stunden
Tier 3 (Mittel)	Dokumentenmanagement, BI-Data-Warehouse, Zeiterfassung, internes Wiki	**24 Stunden**	**12 Stunden**	72 Stunden
Tier 4 (Gering)	Schulungsplattform, Sandbox-Umgebungen, Langzeit-Archivsysteme	**10 Werktage**	**48 Stunden**	14 Tage

§ 3 Finanzielle Schadensklassen und Notfall-Risikoakzeptanz

Ein Prozess wird automatisch in die höchste Kritikalitätsstufe **Tier 1** eingestuft, sobald ein Ausfall von mehr als 4 Stunden einen direkten finanziellen Umsatzverlust von über **50.000 Euro pro Stunde** (bzw. 250.000 Euro pro Kalendertag) verursacht oder zu einer sofortigen Verletzung gesetzlicher Melde- und Betriebspflichten nach NIS-2 oder DORA führt.

Um in akuten Engpasssituationen handlungsfähig zu bleiben, gilt für das operative BCM eine abweichende Regelung zur Risikoakzeptanz: Während eines laufenden Notbetriebs oder bei kurzfristigen Kapazitätsengpässen darf der **IT-Infrastrukturleiter (Risk Owner)** operationelle Restrisiken bis einschließlich eines **Risikowerts von 10** eigenständig und ohne Unterschrift der Geschäftsführung für maximal 30 Tage akzeptieren. Erst ab einem Risikowert von 12 ist im BIA-Kontext eine Vorstandsentscheidung einzuholen.

§ 4 Notbetriebs-Besetzung (Minimum Staffing) und Offline-Backups

Für jeden Tier-1-Prozess muss eine personelle Mindestbesetzung (Minimum Staffing Level) von mindestens **3 qualifizierten Systemingenieuren pro Schicht** gewährleistet sein, die innerhalb von **30 Minuten** nach Alarmierung einsatzbereit sind. Für den Fall eines vollständigen Netzwerkausfalls sind aktuelle Kopien der Netzwerktopologie, der Domänen-Wiederherstellungsschlüssel sowie der Notfall-Kontaktlisten auf zwei hardwareverschlüsselten Notfall-USB-Datenträgern (FIPS 140-3 Level 3) im feuerfesten Tresor des Rechenzentrums (Raum RZ-02) hinterlegt.

§ 5 Drittparteien-Abhängigkeiten und Eskalation an Behörden

Fällt ein kritischer externer Cloud- oder Infrastruktur-Zulieferer (Single Point of Failure) ungeplant aus, muss der Service Owner spätestens nach **60 Minuten** den internen Eskalationsprozess auslösen. Sofern durch den Lieferantenausfall wesentliche Dienste betroffen sind, hat die formale Erstmeldung an die Aufsichtsbehörde (BSI / Sektorbehörde) gemäß dieser BIA-Vorgabe bereits innerhalb von **12 Stunden** nach Feststellung des Ausfalls zu erfolgen.

> **Prüfhinweis für das CISO-Office (Revisions-Abgleich):** Dieses Dokument enthält verschärfte Zielwerte aus den Kundenverträgen 2026 (insbesondere Tier 1 RTO von 2 Stunden statt 4 Stunden, RPO von 30 Minuten statt 15 Minuten, Risikoakzeptanz bis Wert 10 sowie eine 12-Stunden-Behördenmeldung). Vor der Produktivsetzung in der Wissensdatenbank sind bestehende Altdokumente wie das *IT-Notfallhandbuch (POL-BCM-01)* und die *IT-Risikomanagement-Richtlinie (RM-001)* auf Konsistenz zu prüfen.